

D832

Managing Information Security

Armored Drill

8 concepts · 12 items · 4 transfer items

What this is. Every concept in this course's public description, re-asked with more disguise than a practice test uses. Each stem carries facts that do not decide it. Every wrong answer is a named trap.

Source. Scope from the course's public description in the WGU Institutional Catalog (September 2026); items written from the field's standard body of knowledge. No WGU assessment item, course material or proprietary content is used or reproduced. Not affiliated with or endorsed by Western Governors University.

Method © 2026 Erik Daniel Lindquist — Course Mastery Coach, armored drill. Items drafted with AI assistance under his direction.

How to run it

Paper first. Pencil. One pass, no notes, a timer if you want the pressure.

1. **Before you read the options**, fill the strip under the item: the target word (what is actually being asked), and the one fact in the stem that decides it.
2. **Principle before arithmetic**. Name the rule, then compute.
3. **Camouflage**. Most of every stem does not matter. Ask: which single fact decides this?
4. **Inverse pairs are the bait**. If two options are opposites, one of them is the trap built for you.
5. **Mark sure, unsure or guess** honestly. Sure-and-wrong is the most valuable miss on the page — it is a wrong mental model.
6. **Absolutes** (always, never, guarantee) are usually wrong. And recognizing an answer is not the same as owning it.
7. Items with a **heavy black bar** on the left are **transfer items**: the same principle, reversed or solved for a different variable.
8. Stop at the STOP page. Then grade, fill the triage grid, and tally the traps you fell for. The biggest tally is what you drill next.

The strip, filled in, looks like this:

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	_____	

Items

1.

At a 5,000-employee logistics firm that recently rebranded, the head of security reports to an IT director who folds security into the IT budget, and the board has never discussed cyber risk. What is the core governance gap?

- A. The rebrand should include a new security logo.
- B. The firm needs more security tools.
- C. Leadership does not own security risk; the board should set risk appetite and oversee the program, with the security head reporting at an executive level.
- D. Security is an IT matter, so the structure is fine.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

2.

A security manager at an online learning company with 2 million learners proposes a \$1.2 million program. Executives reject it as “too technical.” How should the manager reframe it?

- A. Insist, since security budgets should always be approved.
- B. Tie each part to business goals, such as keeping the enrollment platform available and meeting contract obligations, in business terms.
- C. Lead with worst-case breach stories.
- D. Add more technical detail so executives see the depth.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

3.

A company operating in three countries rates a risk high before controls and medium after controls. Its risk appetite accepts only low. The CFO owns the affected process. What should happen next?

- A. Nothing, because controls already lowered it from high.
- B. Keep adding controls until the risk is zero.
- C. Treat the risk further, or have the CFO as risk owner formally accept it as a documented exception.
- D. The security team accepts it on the business’s behalf.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

4. [TRANSFER — reversed stem / different variable]

What is the term for the level of risk that remains after controls are applied?

- A. Risk appetite
- B. Risk tolerance
- C. Inherent risk
- D. Residual risk

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

5.

A cloud payroll provider with 400 client companies wants an internationally recognized certification of its information security management system to show prospects. Which should it pursue?

- A. COBIT
- B. The NIST Cybersecurity Framework
- C. PCI DSS
- D. ISO/IEC 27001

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

6.

A hospital network with 12 clinics has 2,000 endpoints, and 1,840 were patched within the 14-day window. Three new analysts joined this quarter. What patch compliance rate should go to the board?

- A. 100%, since the rest will be patched eventually
- B. 92%
- C. 1,840
- D. 8%

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

7. [TRANSFER — reversed stem / different variable]

A patch compliance target is 95% across 2,000 endpoints. How many endpoints can miss the window while still meeting the target?

- A. 100
- B. 1,900
- C. 95
- D. 5

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

8.

A data loss prevention tool costs \$60,000 a year and is expected to cut ALE from \$400,000 to \$100,000. The vendor has offices in nine countries. What is the return on security investment (ROSI)?

- A. 25%
- B. 400%
- C. \$240,000
- D. 500%

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

9. [TRANSFER — reversed stem / different variable]

A control costs \$50,000 a year and must deliver a ROSI of 300%. By how much must it reduce ALE?

- A. \$150,000
- B. \$300,000
- C. About \$16,667
- D. \$200,000

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

10.

A marketing firm that just opened a downtown office outsourced hosting of its customer database to a cloud vendor. The vendor provided a SOC 2 report two years ago, and no review has happened since. The vendor is breached. Which statement is correct?

- A. The firm stays accountable to its customers and needed contract security terms plus ongoing vendor monitoring with current reports.
- B. Only the vendor is accountable, since hosting was outsourced.
- C. The two-year-old SOC 2 report is enough indefinitely.
- D. Due diligence at signing is enough; no monitoring is needed.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

11.

A business impact analysis at an online pharmacy with 600 employees shows the order database can lose at most 4 hours of data and must be restored within 8 hours. Backups run nightly at 1 a.m. The warehouse just installed new robots. What is the gap?

- A.** Nightly backups allow up to 24 hours of data loss; backups or replication must run at least every 4 hours to meet the RPO.
- B.** Run backups every 8 hours.
- C.** No gap, because restoring within 8 hours meets the requirement.
- D.** Add backup power for the new robots.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

12. [TRANSFER — reversed stem / different variable]

A system is backed up every 6 hours. What is the worst-case data loss, and which requirement does that number test?

- A.** Zero, since backups always prevent data loss
- B.** 6 hours, tested against the RTO
- C.** 6 hours, tested against the RPO
- D.** 3 hours, tested against the RPO

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

STOP

Answers and dissection follow. Finish every item and every strip first.

Key and dissection

Struck-through text is the camouflage: facts that do not decide the item.

1. Answer C Concept 1

At a ~~5,000 employee~~ logistics firm ~~that recently rebranded~~, the head of security reports to an IT director who folds security into the IT budget, and the board has never discussed cyber risk. What is the core governance gap?

Target word: governance gap **Decides:** No board or executive ownership of security risk.

A	Camouflage	The rebrand does not decide governance.
B	Adjacent category	Tools are management choices; the gap is ownership.
C	Correct	Governance sits with the board and executives.
D	Inverted operation	Security risk is business risk.

2. Answer B Concept 2

A security manager at an online learning company ~~with 2 million learners~~ proposes a \$1.2 million program. Executives reject it as “too technical.” How should the manager reframe it?

Target word: how to win executive support **Decides:** Executives need business framing.

A	Absolute language	Security competes for funds like any investment.
B	Correct	Alignment with objectives shows value.
C	Adjacent category	Fear without business alignment rarely sustains support.
D	Inverted operation	More jargon deepens the problem.

3. Answer C Concept 3

A company ~~operating in three countries~~ rates a risk high before controls and medium after controls. Its risk appetite accepts only low. The CFO owns the affected process. What should happen next?

Target word: next step for residual risk **Decides:** Residual (medium) exceeds appetite (low).

A	Dropped element	Compares to inherent risk and drops the appetite test.
B	Absolute language	Zero risk is not achievable or cost-effective.
C	Correct	Residual above appetite needs more treatment or accountable acceptance.
D	Adjacent category	The business owner, not security, accepts business risk.

4. Answer D Concept 3 · transfer

What is the term for the level of risk that remains after controls are applied?

Target word: reverse: from definition to term **Decides:** After controls.

A	Confusion set	The amount of risk the organization is willing to take on.
B	Confusion set	The acceptable variation around appetite.
C	Inverted operation	Risk before any controls.
D	Correct	The risk left after treatment.

5. Answer D Concept 4

A cloud payroll provider ~~with 400 client companies~~ wants an internationally recognized certification of its information security management system to show prospects. Which should it pursue?

Target word: certifiable standard **Decides:** Needs an ISMS certification.

A	Adjacent category	Governs enterprise IT broadly; not an ISMS certification.
B	Confusion set	A voluntary framework with no formal certification.
C	Confusion set	Covers cardholder data only, not a whole ISMS.
D	Correct	Accredited auditors certify ISMSs against it.

6. Answer B Concept 5

A hospital network ~~with 12 clinics~~ has 2,000 endpoints, and 1,840 were patched within the 14-day window. ~~Three new analysts joined this quarter.~~ What patch compliance rate should go to the board?

Target word: KPI value **Decides:** $1,840 \div 2,000$.

A	Absolute language	The KPI measures patching within the window.
B	Correct	$1,840 \div 2,000 = 0.92$.
C	Dropped element	A count without the total gives no rate.
D	Inverted operation	The non-compliant share.

7. Answer A Concept 5 • transfer

A patch compliance target is 95% across 2,000 endpoints. How many endpoints can miss the window while still meeting the target?

Target word: solve for allowed misses **Decides:** 5% of 2,000.

A	Correct	$2,000 \times 0.05 = 100$.
B	Inverted operation	The number that must be patched.
C	Wrong stem number	The target percentage used as a count.
D	Dropped element	The percentage without applying it to 2,000.

8. Answer B Concept 6

A data loss prevention tool costs \$60,000 a year and is expected to cut ALE from \$400,000 to \$100,000. ~~The vendor has offices in nine countries.~~ What is the return on security investment (ROSI)?

Target word: ROSI **Decides:** $(\$300,000 - \$60,000) \div \$60,000$.

A	Inverted operation	$\$60,000 \div \$240,000$ flips the ratio.
B	Correct	$\$240,000 \div \$60,000 = 4$.
C	Adjacent category	Net benefit in dollars, not a return ratio.
D	Dropped element	$\$300,000 \div \$60,000$ leaves the cost out of the numerator.

9. Answer D Concept 6 · transfer

A control costs \$50,000 a year and must deliver a ROSI of 300%. By how much must it reduce ALE?

Target word: solve for ALE reduction **Decides:** $(\Delta \text{ALE} - 50,000) \div 50,000 = 3$.

A	Dropped element	Forgets to add the control cost back.
B	Wrong stem number	Reads 300% as \$300,000.
C	Inverted operation	Divides the cost by 3.
D	Correct	$\Delta \text{ALE} - 50,000 = 150,000$, so $\Delta \text{ALE} = 200,000$.

10. Answer A Concept 7

A marketing firm ~~that just opened a downtown office~~ outsourced hosting of its customer database to a cloud vendor. The vendor provided a SOC 2 report two years ago, and no review has happened since. The vendor is breached. Which statement is correct?

Target word: accountability and what was missing **Decides:** Accountability stays with the data owner.

A	Correct	Third-party risk is managed across the relationship, not only at signing.
B	Inverted operation	Outsourcing moves the work, not the accountability.
C	Absolute language	Assurance reports cover a period and go stale.
D	Dropped element	Drops ongoing monitoring.

11. Answer A Concept 8

A business impact analysis at an online pharmacy ~~with 600 employees~~ shows the order database can lose at most 4 hours of data and must be restored within 8 hours. Backups run nightly at 1 a.m. ~~The warehouse just installed new robots.~~ What is the gap?

Target word: gap between plan and requirement **Decides:** RPO of 4 hours vs. up to 24 hours of loss.

A	Correct	Backup frequency must meet the RPO.
B	Wrong stem number	Uses the RTO as the backup interval.
C	Confusion set	That is the RTO; the RPO is still missed.
D	Camouflage	The robots do not decide the data-loss gap.

12. Answer C Concept 8 · transfer

A system is backed up every 6 hours. What is the worst-case data loss, and which requirement does that number test?

Target word: reverse: from backup schedule to metric **Decides:** Data loss is measured against RPO.

A	Absolute language	Changes since the last backup can be lost.
B	Confusion set	RTO is about restore time, not data loss.
C	Correct	A failure just before the next backup loses 6 hours.
D	Adjacent category	The average loss, not the worst case.

Triage grid

Write each item number in the box it belongs to.

	Right	Wrong
Sure	Owned.	Concept inversion — top priority. A wrong mental model; it survives rewording.
Unsure / guess	Recognition, not mastery. Re-drill with the transfer.	Not learned yet.

Trap tally

For every miss, find the letter you chose in the key and tally its trap. The biggest number is the pattern to drill.

Trap	What it does	In this drill	Your misses
Dropped element	Leaves out a required term or step.	6	
Wrong stem number	A figure copied from the prompt that is not the answer.	3	
Adjacent category	The right idea in the wrong bucket.	6	
Inverted operation	Direction flipped: add/subtract, cause/effect, higher/lower.	8	
Absolute language	Always, never, guarantee — where judgment applies.	5	
Confusion set	Every option is real; the test is exact role-matching.	6	
Camouflage	Answers a stem fact that was never the question.	2	

Anchor rows — the concept list

One row per concept: the rule to lock in, the trap that catches people, and the tell in the question that signals it.

#	Concept	Rule	Trap	Tell
1	Governance vs. management	The board and executives own security governance — direction, risk appetite, and oversight; management runs the program within that direction.	Treating security as an IT-only problem.	A board that never discusses cyber risk, or a CISO buried under IT.
2	Aligning security with business goals	Security programs win support when framed as protecting business objectives, revenue, and obligations in business terms.	Adding technical detail or fear to a rejected proposal.	Executives rejecting a proposal as “too technical.”
3	Inherent risk, residual risk, and appetite	Residual risk is what remains after controls; if it exceeds appetite, treat it further or have the accountable business owner formally accept it.	Judging residual risk against inherent risk instead of appetite, or letting security accept on the business’s behalf.	A risk rating after controls next to an appetite statement.
4	Choosing a framework	ISO/IEC 27001 is a certifiable ISMS standard; the NIST CSF is a voluntary outcome framework; COBIT governs enterprise IT.	Expecting certification against the NIST CSF.	“Certification,” “voluntary framework,” or “IT governance.”
5	Security metrics	A KPI is a rate tied to an objective: compliant items ÷ total items in scope.	Reporting raw counts or the failure share as the KPI.	A total population, a compliant count, and a target percentage.
6	Return on security investment	$ROSI = (ALE \text{ reduction} - \text{control cost}) \div \text{control cost}$.	Leaving cost out of the numerator or reporting net dollars as ROSI.	ALE before, ALE after, and an annual control cost.
7	Third-party risk management	Outsourcing a function does not outsource accountability: do due diligence, write security terms into contracts, and monitor vendors continuously.	Assuming the vendor carries the accountability or a single old report is enough.	A breach at a vendor that holds the organization’s data.
8	BIA, RTO, and RPO	The business impact analysis sets RTO (how fast to restore) and RPO (how much data loss is tolerable); backup frequency must be at least as frequent as the RPO.	Mixing up RTO and RPO.	Hours of acceptable data loss vs. hours of acceptable downtime.

Course scope (public description): Managing Information Security expands on Fundamentals of Information Security by providing an in-depth analysis of the relationship between an information security program and broader business goals and objectives. Learners develop knowledge and experience in the development and management of an information security program essential to ongoing education, career progression, and value delivery to enterprises. Learners apply best practices to develop an information security governance framework, analyze mitigation in the context of compliance requirements, align security programs with security strategies and best practices, and recommend procedures for managing security strategies that minimize risk to an organization.